

# Exploiting AI Agents to Trigger Secondary Vulnerabilities

---

Author: Moe Htet Ar Kar (Phoe Cho)

## 1. Vulnerability Concept & Mechanics

AI agents operating within complex web ecosystems interact with underlying services, databases, APIs, and microservices. When an agent acts as an intermediary, attackers may attempt to use its capabilities to reach and interact with secondary vulnerabilities that would otherwise be difficult to access directly.

Potential secondary vulnerabilities include SSRF, IDOR, path traversal, SQL injection, and insecure internal APIs.

## 2. Attack Vector & Exploitation Methodology

### Internal Topology Mapping

Assess whether the agent can access internal network resources, fetch URLs, or communicate with internal services through its integrated tools.

### Exploit Chaining

Determine whether prompt manipulation or other agent-level weaknesses can cause the agent to send unauthorized requests to vulnerable internal endpoints.

### Data Retrieval & Exfiltration

Assess whether sensitive information retrieved through an internal resource can subsequently be exposed through the agent's response.

## 3. Validation & Impact

- **Impact:** Potential Server-Side Request Forgery (SSRF), access to internal services or cloud metadata, IDOR exploitation, and internal network exposure.
- **Validation:** Verify whether the AI agent can interact with restricted internal resources and whether sensitive information can be returned to an unauthorized user.

## 4. Remediation & Hardening

- Implement strict egress filtering and network segmentation for AI-agent execution environments.
- Block access to private and restricted network ranges where such access is not explicitly required.
- Apply URL allowlisting for web-fetching tools used by AI agents.
- Perform comprehensive security assessments of internal microservices and APIs accessible through agentic workflows.